ZCAS UNIVERSITY

BACHELOR OF SCIENCE IN CYBER SECURITY

CIT3372 CCNA SECURITY

FINAL EXAMINATION

TIME ALLOWED	:	**WRITING – THREE HOURS**
		READING – 5 MINUTES
DATE	:	**4th DECEMBER, 2024**

INSTRUCTIONS:

1. Section A: this question is **compulsory** and must be attempted.
2. Sections B: Answer **THREE (3)** questions from this section.
3. This examination paper carries a total of **100 marks.**
4. Candidates must **not turn this page** until the invigilator tells them to do so.

SECTION A – COMPULSORY

Study the scenario below and answer the following questions:

QUESTION 1

Cisco averts cyber disaster after successful phishing attack

In August 2022, Cisco revealed that it fought off a potentially damaging cyber incident that unfolded after a threat actor conducted a phishing attack on one of its employees by abusing their personal Google account to access its network. The network hardware supplier said the attacker was likely an initial access broker with links to the UNC2447 cyber-crime gang, a Chinese ransomware operator known as Yanluowang, and the Lapsus group – a gang of teens who abused failings in multifactor authentication (MFA) to target multiple tech companies earlier this year. Cisco disclosed it had been attacked on 10th August after its name appeared on Yanluowang's Dark web leak site, but the attack unfolded more than two months later on 24 May.

"During the investigation, it was determined that a Cisco employee's credentials were compromised after an attacker gained control of a personal Google account where credentials saved in the victim's browser were being synchronized," said the Talos team in its disclosure notice. "The attacker then conducted a series of sophisticated voice phishing attacks under the guise of various trusted organizations attempting to convince the victim to accept multifactor authentication (MFA) push notifications initiated by the attacker. "The attacker ultimately succeeded in achieving an multifactor authentication (MFA) push acceptance, granting them access to the Virtue Private Network (VPN) in the context of the targeted user."

After gaining access, the attacker conducted a variety of activities to achieve persistence, cover their tracks and elevate their privileges within Cisco's network. They were able to move into Cisco's Citrix environment, compromise a number of servers and obtained privileged access to domain controllers. Ultimately, they were successfully able to exfiltrate the contents of a Box folder associated with the compromised employee's account, and employee authentication data from Active Directory. Once detected and removed from the network, the threat actor repeatedly attempted to regain access by targeting employees who they suspected had made single character changes to their passwords following a mandated credential reset across Cisco.

"The incident was contained to the corporate IT environment and Cisco did not identify any impact to any Cisco products or services, sensitive customer data or employee information, Cisco intellectual property, or supply chain operations," said Cisco in a statement. "No customer or partner action is required for Cisco products or services. Cisco has updated its security products with intelligence gained from observing the bad actor's techniques, shared Indicators of Compromise [IOCs] with other parties, reached out to law enforcement and other partners, and is sharing further technical details through a Talos blog to help cyber defenders learn from our observations." The team added: "Cisco has extensive IT monitoring and remediation capabilities. We have used these capabilities to implement additional protections, block any unauthorized access attempts, and mitigate the security threat. We are also putting additional emphasis on employee cyber security hygiene and best practices to avoid similar instances in the future."

Having read and understood the scenario above, answer the following questions.

a) The first activity done by an attacker is called reconnaissance. Discuss this concept and how this activity might have been done on Cisco Systems. (6 marks)

b) Explain two (2) weaknesses that attackers wanted to exploit in the Cisco system. (6 marks)

c) Discuss five (5) techniques that Cisco used to prevent these attacks from further exploitation. (10 marks)

d) Discuss how phishing attacks are conducted and the consequences thereof. (4 marks)

e) Other methods used in social engineering attacks include pretexting and phishing. With the use of examples, discuss these methods. (8 marks)

f) Microsoft experienced a similar attack in 2017, the WannaCry attack which could spread through networks. Known as a cryptoworm, this ransomware infected more than 200,000 computers around the world. The attack exploited a vulnerability in Windows that Microsoft had already identified and patched. However, many users hadn't updated their systems, leaving their computers vulnerable to cyber-attacks. WannaCry cost an estimate of $4 billion. Describe three (3) challenges on users and clients as a result of this attack. (6 marks)

[Total: 40 marks]

SECTION B: Answer any three (3) questions in this section.

QUESTION 2

a) AAA, authentication, authorization, and accounting framework is used to manage the activity of the user on a network. RADIUS, TACACS+, and Diameter are the three most popular and widely implemented AAA protocols. Discuss the differences between the functionalities of RADIUS or TACACS+ protocols. (8 marks)

b) A newly established betting company has decided to purchase a firewall due to the advent of persistent cyber-security attacks from unknown devices and applications. Discuss the two (2) implementations of firewalls they could use to protect the organization. (6 marks)

c) A virtual private network (VPN) is a network that uses public telecommunication, such as the Internet, instead of leased lines to communicate. One of the application of VPNs is the implementation of intranets and extranets. Explain the of use these networks. (6 marks)

[Total: 20 marks]

QUESTION 3

a) Access Control Lists (ACLs) enable you to control traffic into and out of your network. An ACL can be as simple as permitting or denying network hosts, IP addresses or to control network traffic based on the TCP port being used. Write down an ACL that can do the following:

i) Allow traffic from all devices on network 192.168.10.0 and block all others (2 marks)

ii) Deny Hypertext Transfer Protocol (HTTP) traffic from network 10.0.0.0 (3 marks)

iii) Deny telnet traffic from network 130.80.0.0 (3 marks)

iv) Deny domain name system (DNS) traffic from network 200.45.12.0 (3 marks)

b) Access Control Lists (ACLs) limit network traffic and increase network performance based on the following three (3) parameters. Explain these parameters.

i) One ACL per protocol (2 marks)

ii) One ACL per Direction (4 marks)

iii) One ACL per Interface (3 marks)

[Total: 20 marks]

QUESTION 4

a) Data Link Layer (Layer 2) switches are susceptible to many of the same Layer 3 attacks as routers; therefore, most of the security techniques for routers also apply to switches. However, switches also have their own unique network attacks. With the use of one (1) example in each case, explain three (3) attacks on switches. (9 marks)

b) In point-to-point protocol (PPP), we can secure communication between two points using authentication protocols. There are two ways in which we can configure PPP authentication security as listed below. Explain these authentication methods.

i) PAP (Password Authentication Protocol) (3 marks)

ii) CHAP (Challenge-Handshake Authentication Protocol) (5 marks)

c) Describe the functionality of the following syntax (3 marks)

```
Sw-Floor-1# configure terminal
Sw-Floor-1(config)# line vty 0 15
Sw-Floor-1(config-line)# password cisco
Sw-Floor-1(config-line)# login
Sw-Floor-1(config-line)# end
Sw-Floor-1#
```

[Total: 20 marks]

QUESTION 5

a) Cryptography, can also be defined as the art and science of making a cryptosystem that is capable of providing information security. With the use of two (2) practical examples in industry, explain the differences between symmetric and asymmetric cryptosystems. (8 marks)

b) ACLs can act as firewalls to filter packets and eliminate unwanted traffic. Every ACL should be placed where it has the greatest impact on efficiency. Discuss the placement of standard and extended ACLs. (6 marks)

c) In recent past, the Banking sector in Zambia has been having challenges of exposure of user credentials or personal identification information, subsequently used by criminals for fraudulent financial activities. Discuss the methods used by these criminals to acquire these credentials and how this affects these financial institutions. (6 marks)

[Total: 20 marks]

END: ALL THE BEST!!!